

Supply Chain Vulnerabilities in the Supply Chain Vulnerability Ecosystem

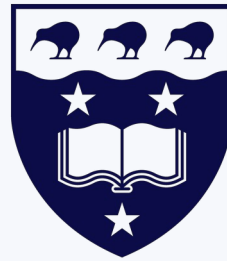
Kris Hardy

kris.hardy@vltbcn.com

LinkedIn: [krishardy](#)

Mastodon: [@nonlinear@mastodon.nz](#)

Thank You to Our Sponsors and Hosts!



Waipapa
Taumata Rau
**University
of Auckland**



BASTION

SECURITY GROUP



**SECURE
CODE
WARRIOR**



plexure



Without them, this conference couldn't happen.

What is the CVE Program?



<https://www.cve.org/>

A free, publicly-available database of disclosed cybersecurity vulnerabilities.

Currently over 291,000 Common Vulnerabilities and Exposures (CVE) records.

Example: <https://www.cve.org/CVERecord?id=CVE-2025-9578>

- Vendor, Product, Affected versions
- References
- Common Weakness Enumerations (CWE) – What is the type of vulnerability/root cause?
- Common Vulnerability Scoring System (CVSS) – How severe is the vulnerability?
- Stakeholder-Specific Vulnerability Category (SSVC) – When should we remediate?
- Known Exploited Vulnerability (KEV) – Is the vulnerability being actively exploited?

Collapse all

Required CVE Record Information

CNA: VulDB

Published: 2025-09-02 **Updated:** 2025-09-02
Title: Campcodes Farm Management System ReviewInput.Php Sql Injection
Tags: [x_freeware](#)

Description

A vulnerability was found in Campcodes Farm Management System 1.0. This affects an unknown part of the file / reviewInput.php. Performing manipulation of the argument results in sql injection. The attack is possible to be carried out remotely. The exploit has been made public and could be used.

CWE 2 Total
[Learn more](#)

- [CWE-89: SQL Injection](#)
- [CWE-74: Injection](#)

CVSS 4 Total
[Learn more](#)

Score	Severity	Version	Vector String
6.9	MEDIUM	4.0	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:N/SI:N/SA:N/E:P
7.3	HIGH	3.1	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:P/RL:X/RC:R
7.3	HIGH	3.0	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:P/RL:X/RC:R

Product Status
[Learn more](#)

Vendor Campcodes	Product Farm Management System
----------------------------	--

CWE 2 Total

[Learn more](#)

- [CWE-89: SQL Injection](#)
- [CWE-74: Injection](#)

Score	Severity	Version
6.9	MEDIUM	4.0

How severe?

Vendor
Campcodes

Product
Farm Management System

Versions 1 Total

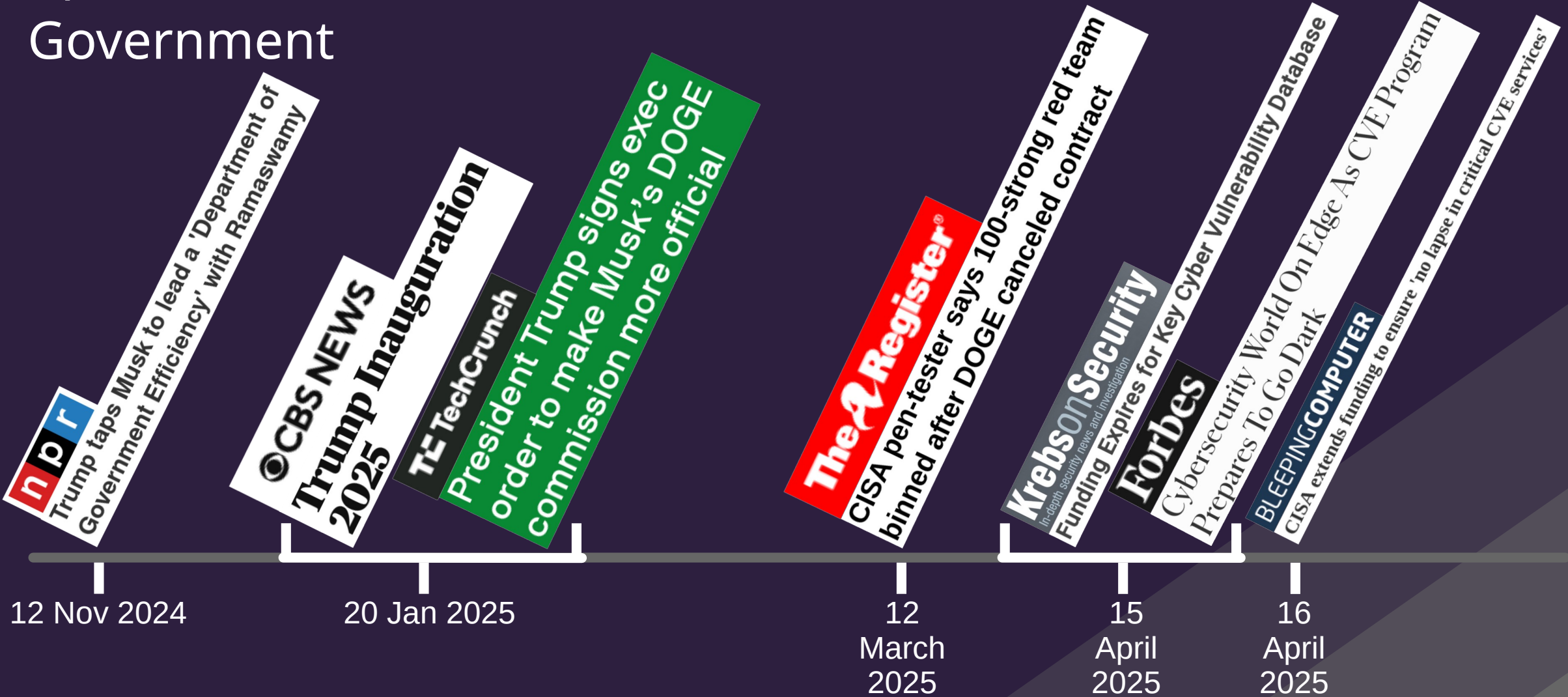
Default Status: unknown
Affected

- affected at 1.0

What software is affected?

What weaknesses / root causes?

April 2025 – Massive Contract Terminations Across the US Government



April 2025 – Massive Contract Terminations Across the US Government

Cybersecurity and Infrastructure Security Agency (CISA) cut 40% of its workforce cut.

An 11-month contract extension is awarded for the CVE program just hours before the CVE program is shut down.

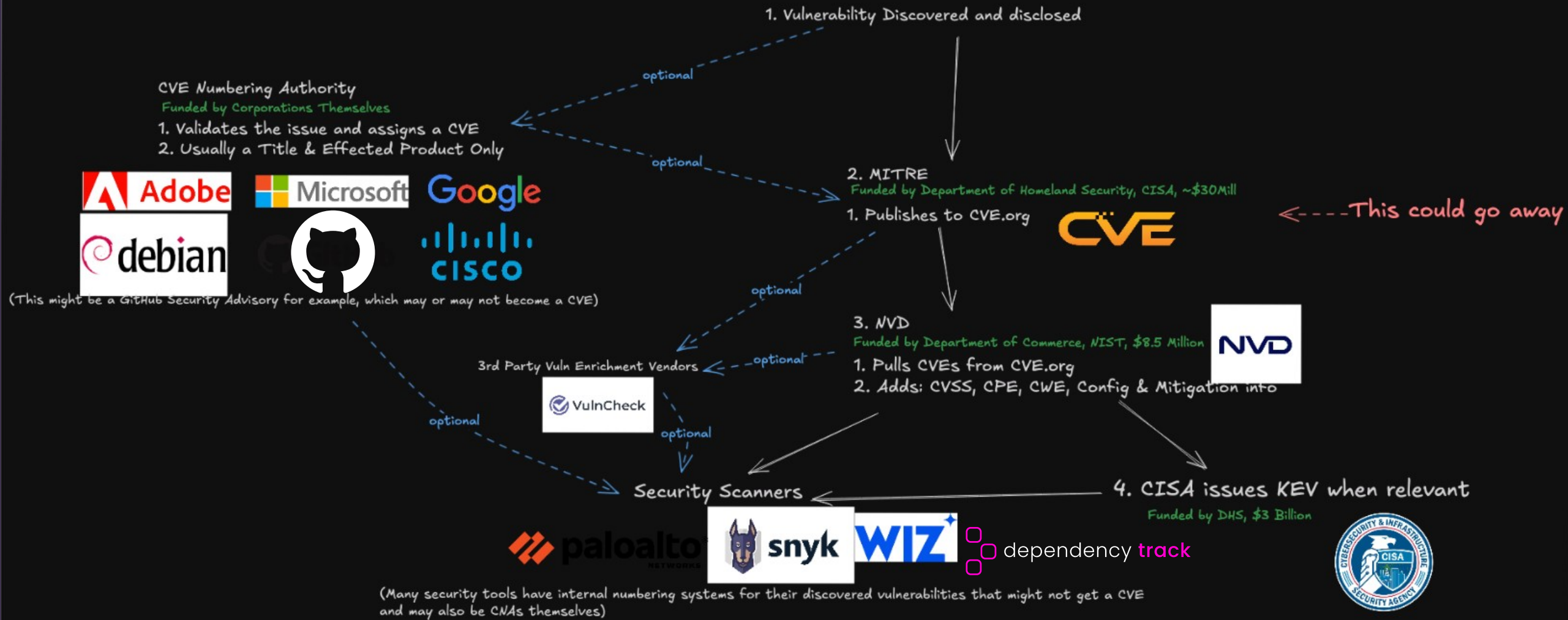
The CVE Foundation is created to diversify funding sources. So, problem solved?

What would happen if the MITRE CVE program is killed AND the CVE Foundation failed?

Thought experiment time...

What do you do about supply chain vulnerabilities in the supply chain vulnerability ecosystem?

I'm just a Vuln: How a disclosure becomes a finding



Auth bypass in ADAL.js – Microsoft did not issue a CVE

1. I discover vulnerability in
Azure Active Directory Library for JavaScript
(ADAL.js)

2. I Submit
report



Microsoft

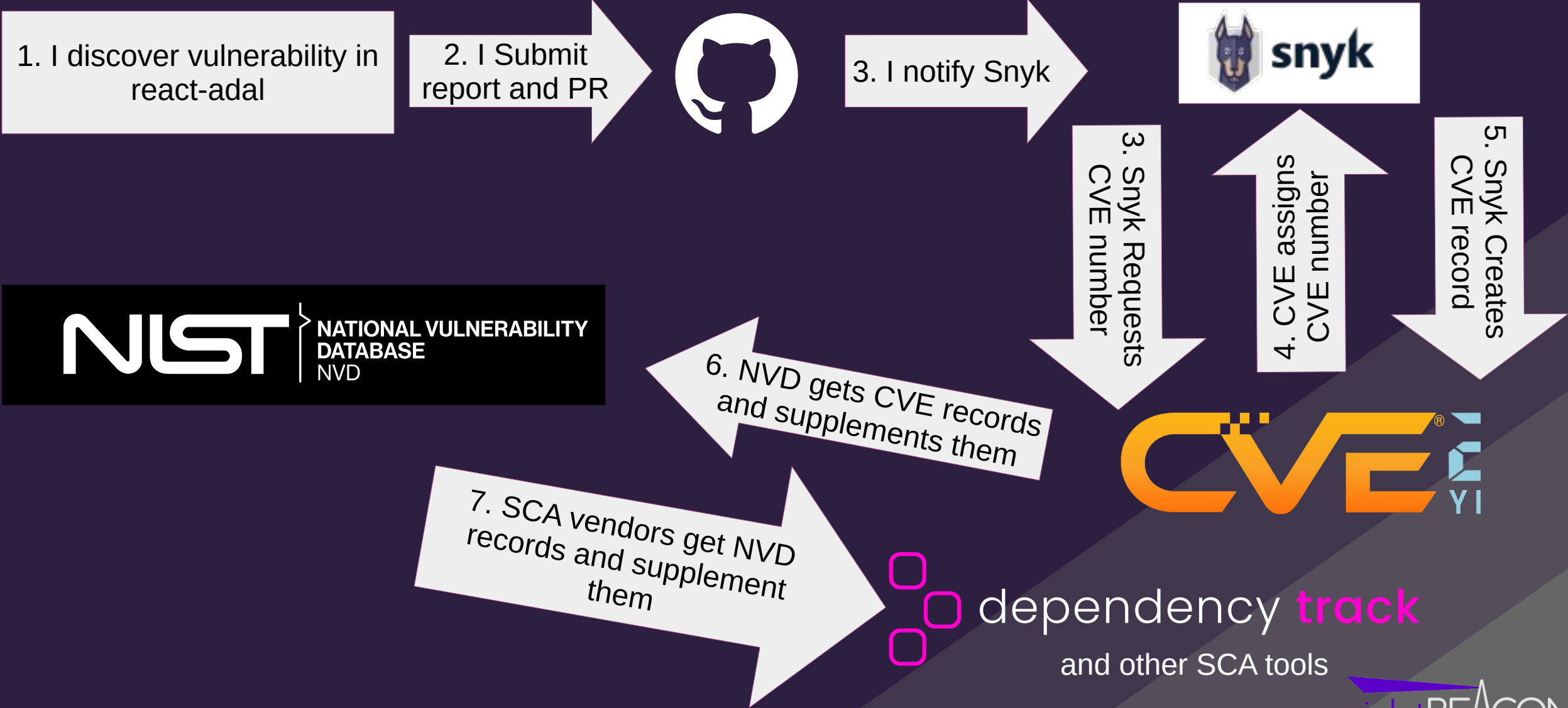
3. MS patches
ADAL.js



No CVE issued due to ADAL.js being at “End-of-Life”.

No easy way to notify all users of ADAL.js.

CVE-2020-7787 (Auth bypass in react-adal.js)



CVE-2020-7787 (Auth bypass in ADAL.js and react-adal.js)

- I find a vulnerability in Azure Active Directory Library for JS (adal.js)
- I submit the report to Microsoft
- Microsoft is a CVE Number Authority (CNA), so they're supposed to request a CVE number, but don't have to since the library is "End-of-Life".
 - They never published it. **This is one of the complaints with the CVE program.)**
- Microsoft fixed the library.
- I find that react-adal embeds (vendors) the ADAL.js. (Another issue: **Multi-vendor coordination is difficult with the CVE program**)
- I submit a PR and try to get the maintainer to update the project. They don't respond.
- I contact Snyk (another CNA) and they issue CVE-2020-7787
- Both Snyk, I and other users eventually get the maintainer to update the library.
- <https://www.cve.org/CVERecord?id=CVE-2020-7787>

Interesting Facts about the CVE program

- There are 469 CVE Number Authorities (CNAs), each with an approved scope.

Microsoft Corporation	Microsoft issues only, excluding end-of-life (EOL) as listed in the Microsoft Lifecycle Policy .	CNA	Vendor	USA
-----------------------	--	-----	--------	-----

- When the CVE program was under threat, CNAs were pre-requesting blocks of CVE numbers in the hope that it would come back online soon.
- Not all CVEs or CNAs are created equal. Some CNAs create huge numbers of low-value CVEs that aren't actually vulnerabilities.
- It sometimes takes years before a CVE report is published due to backlogs.
 - This depends heavily upon the CNA.
 - This led to the creation of a “pirate” CNA at one point that tried to fix the backlog.
- Some CNAs are software vendors (such as Microsoft, Adobe, Oracle, etc.), so they have a vested interest in only publishing CVEs when absolutely necessary.
- Multi-vendor disclosures are incredibly difficult due to each CNA being in a silo.

What depends on CVE? (a small sample)



dependency **track**



cvemon



VulnCheck

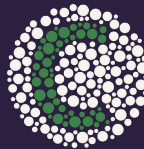


FLASHPOINT



feedly

ATTACKERKB



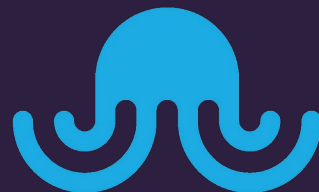
SOCRadar
FREE TOOLS



circl.lu
Computer Incident
Response Center
LUXEMBOURG



**EXPLOIT
DATABASE**



vFeed



CVESky



OPENVAS
by Greenbone



BLACKDUCK



snyk

violetBE/CON

Are there other options?

Yes, but a few things need to be weighed:

- 1) How many standards are there?
- 2) Can we merge feeds without causing duplicates? (This is currently a problem)
- 3) How much work will be required to keep the SCA system up-to-date if feeds change or go dark?

GitHub Security Advisory Database (GHSA)



<https://github.com/advisories>

Not dependent upon CVE and NIST National Vulnerability Database (NVD), but consumes their data.

It is mostly concerned with *public* repositories that exist on GitHub.

Projects not on GitHub have very limited details, and no Common Platform Enumeration (CPE) information (application, version, etc.)

Some dependency management tools for language ecosystems rely on GitHub Advisories.

It is a service of GitHub, a commercial company owned by Microsoft, so that is good or bad depending upon your viewpoint.

China National Vulnerability Database (CNVD) and China National Vulnerability Database of Information Security (CNNVD)

<https://www.cnnvd.org.cn/>

In Chinese. Run by the Chinese government.

Independent of CVE and NVD, but they do ingest the CVE & NVD databases.

Contains 40 more Chinese vendors than NVD (as of 2021).

Quality appears to be similar to NVD.

I. Forain, R. de Oliveira Albuquerque and R. T. de Sousa Júnior, "Towards System Security: What a Comparison of National Vulnerability Databases Reveals," 2022 17th Iberian Conference on Information Systems and Technologies (CISTI), Madrid, Spain, 2022, pp. 1-6, doi: 10.23919/CISTI54924.2022.9820232.

TABLE V. DATA SUMMARY

<i>Feature</i>	<i>NVD</i>	<i>CNVD</i>	<i>CNNVD</i>
Vulnerability	178,906	99,261	180,567
Missing Weeks	0	6	0
Missing CVE	0	23,281	9,963
Repeated ID	0	88	0
Repeated CVE	0	108	15
Wrong CVE	0	193	0
Missing CVSS	10,933	326	8,466
Missing CPE	11,143	113	25,694
Missing CWE	10,928	99,261	180,567
Missing Reference	24,035	19,012	5,786

Japan Vulnerability Notes (JVN)



<https://jvn.jp/en/>

Independent of CVE, but contains a link if one exists. The vast majority of their records are imported from NIST NVD.

<https://jvn.jp/en>

Their feed is “CVE Compatible”.

Could be valuable as a supplementary feed.

European Union Vulnerability Database (EUVD)



<https://euvd.enisa.europa.eu>

They have their own numbering system (EUVD-year-#)

Aggregate CVE, GitHub Security Advisories, GSD

Run by the European Union Agency for Cybersecurity (ENISA), and was publicly launched when funding to CVE was threatened.

My opinion: This has the highest change of success, and duplicate entries should not be a problem as long as EUVD and CVE remain in-sync.

Open Source Vulnerability Database (OSV)



<https://osv.dev/>

Free and open database, funded by Google.

Aggregates ~22 vulnerability feeds, including: GitHub Advisory Database, PyPI Advisory Database, Go Vulnerability Database, Rust Vulnerability Database, Global Security Database, OSS-Fuzz, OpenSSF Malicious Packages, Python Software Foundation Database

Uses the OpenSSF OSV format.

You subscribe to feeds that you are interested in.

Duplicates can be an issue if you are ingesting non-OpenSSF OSV feeds (CVE, GHSA, etc.) and CVE/GHSA ids aren't included.

Global CVE Allocation System (GCVE)



<https://gcve.eu/>

Decentralized vulnerability identification and number system.

Funded by the European Union.

GCVE Numbering Authorities (GNAs) can allocate identifiers independently without requesting them from a central authority.

Vulnerability-Lookup: Open Source EU platform to correlate vulnerabilities from various sources. Shortcomings they found in ID allocation and correlation led to them creating GCVE.

<https://vulnerability.circl.lu/> (Instance at CIRCL Luxembourg)

<https://www.vulnerability-lookup.org/>



Global Security Database (GSD)

This is a good reminder that data feeds can and do go dark.

GSD was an open-source project by the Cloud Security Alliance in order to move from the CVD system to a more collaborative process.

The last commit was in 2024.

<https://gsd.id> does not resolve.

I couldn't find an official announcement of it closing. It just disappeared and the repo was put in read-only mode.

Industry-Specific Feeds

- Industrial Control Systems
 - CISA Industrial Control System Cybersecurity Advisories
 - https://www.cisa.gov/news-events/cybersecurity-advisories?f%5B0%5D=advisory_type%3A95
- Medical Devices
 - CISA Medical Advisories
 - https://www.cisa.gov/news-events/cybersecurity-advisories?f%5B0%5D=advisory_type%3A96
 - UK Medical Risks & Vulnerabilities (NMRV) database
 - <https://ncrv.org.uk/>

Defensive Considerations

- Consider supply chain vulnerabilities in your supply chain
- Understand the limitations of your vulnerability management program and data feeds
- Consider how you will deal with business models changing, especially for commercial vendors.
- To SCA tool vendors: Diversify your data feeds, or at least make your system pluggable to prepare for changes in the ecosystem.

Thanks to

- Josh Bressers and Brian Krebs inviting me to the Extended Vulnerability Community (EVC) discord group.
- Background information from the EVC group about MITRE and the CVE project, especially jericho, Josh Bressers and Patrick Garrity
 - <https://jericho.blog/2025/04/24/cve-the-big-vote-of-no-confidence/>
 - <https://opensourcesecurity.io/2025/2025-08-cve-patrick-garrity/>
- Olle Johansson for sharing your ideas on a Global Vulnerability Database.